

Finly API Contract

1) Contract Scope

This document defines request/response behavior, auth requirements, and error semantics for Finly APIs under `/api/v1`.

2) Base URL and Versioning

- Canonical API base: `/api/v1`
- Legacy paths may redirect to `/api/v1` via middleware.

3) Authentication

- Scheme: Bearer JWT
- Header: `Authorization: Bearer <token>`
- Token issued by: `POST /api/v1/auth/login` and `POST /api/v1/auth/signup`

Admin-only endpoints are guarded by role checks and return 403 when role is not admin.

4) Standard Response Envelope

4.1 Success shape

```
{  
  "success": true,  
  "data": {},  
  "meta": {}  
}
```

Notes:

- `data` is object or array depending on endpoint.
- `meta` contains pagination/filter details where relevant.

4.2 Paginated success shape

```
{  
  "success": true,  
  "data": [],  
  "meta": {  
    "total": 120,  
    "limit": 20,  
    "offset": 0,  
    "page": 1,  
    "total_pages": 6,  
    "has_next": true,  
    "has_prev": false,  
  }  
}
```

```

    "filters": {}
  }
}

```

4.3 Error shape

```

{
  "success": false,
  "error": "Invalid credentials",
  "error_code": "ERR_401",
  "path": "/api/v1/auth/login",
  "timestamp": "2026-04-16T11:04:33.206966+00:00"
}

```

Validation errors include a serialized `detail` payload.

5) Common Query Conventions

- Pagination: `limit`, `offset`
- Sorting: `sort_by`, `sort_order`
- Date filters: `start_date`, `end_date`
- Search: `search`

Transactions also support archive semantics:

- `archive_filter=active|archived|all`

6) Key Endpoint Groups

Auth

- POST `/api/v1/auth/signup`
- POST `/api/v1/auth/login`
- POST `/api/v1/auth/forgot-password`
- POST `/api/v1/auth/reset-password`
- POST `/api/v1/auth/change-password`

User domain

- GET `/api/v1/users/me`
- PUT `/api/v1/users/me`
- DELETE `/api/v1/users/me`

Transactions

- POST `/api/v1/transactions`
- GET `/api/v1/transactions`
- PUT `/api/v1/transactions/{id}`
- DELETE `/api/v1/transactions/{id}`

- GET /api/v1/transactions/export

Budgets

- POST /api/v1/budgets
- GET /api/v1/budgets
- GET /api/v1/budgets/summary
- GET /api/v1/budgets/{id}/progress

Analytics

- GET /api/v1/summary
- GET /api/v1/summary/dashboard
- GET /api/v1/summary/monthly
- GET /api/v1/summary/by-category
- GET /api/v1/summary/insights

Admin (admin role required)

- GET /api/v1/admin/dashboard
- GET /api/v1/admin/analytics
- GET /api/v1/admin/users
- PUT /api/v1/admin/users/{user_id}/block
- PUT /api/v1/admin/users/{user_id}/unblock

7) Error Code Reference

Code	Typical HTTP status	Meaning
ERR_VALIDATION	422	Request schema/field validation failed
ERR_400 / ERR_BAD_REQUEST	400	Invalid request data
ERR_401 / ERR_UNAUTHORIZED	401	Invalid or expired credentials/token
ERR_403 / ERR_FORBIDDEN	403	Not allowed for role/status
ERR_NOT_FOUND	404	Resource missing
ERR_CONFLICT / ERR_DUPLICATE	409	Unique/conflict violation
ERR_RATE_LIMITED	429	Rate limit exceeded
ERR_DB_UNAVAILABLE	503	Database temporarily unavailable
ERR_INTERNAL	500	Generic server failure

8) Rate Limiting Behavior

- Global API limiter (except selected routes) returns 429 with:
 - X-RateLimit-Limit
 - X-RateLimit-Remaining
 - X-RateLimit-Reset
- Auth-specific limiters apply to:

- login attempts
- signup attempts
- password reset request attempts
- password reset verify attempts

9) Compatibility Rules

- Keep backward compatibility within `/api/v1` unless explicitly documented.
- Preserve response envelope keys (`success`, `data`, `meta` for success; `success`, `error`, `error_code` for errors).
- New optional fields are additive; avoid removing or renaming existing fields without version bump.

10) Verification Checklist for API Changes

1. Validate auth token issuance and protected route access.
2. Validate pagination metadata integrity.
3. Validate standardized error shape for expected failures.
4. Validate admin RBAC boundaries with user/admin accounts.
5. Update this document when endpoint semantics change.